

Manual 40 — Implementação Controlada da Política de Segurança CJIS

****Linha de base controlada:**** FBI CJIS Security Policy Version 6.1, de 25 de junho de 2026, sujeita a reverificação no momento do release.

****Limite:**** requisitos da política do FBI, requisitos de implementação da CSA estadual, adendos/acordos de segurança, contratos, materiais complementares e práticas da organização permanecem como camadas de fonte distintas.

****Regra de release:**** reverificar a política CJIS vigente do FBI e os requisitos CSA aplicáveis no congelamento do candidato.

Chapter 01 — Propósito, escopo e hierarquia de fontes

Estabeleça a hierarquia controlada de fontes CJIS, método de aplicabilidade, responsáveis, controle de mudanças e índice de evidências. Não trate exemplos, materiais do resource center ou práticas locais como texto vinculante independente da política do FBI.

Chapter 02 — Aplicabilidade e limites de CJI

Determine se sistemas, usuários, locais, interfaces e provedores acessam, processam, transmitem, armazenam ou suportam Criminal Justice Information. Registre inclusões, exclusões e decisões ambíguas com justificativa vinculada às fontes.

Chapter 03 — Modelo de agência, CSA e responsabilidades

Defina responsabilidades de agência, CSA, contratação, hospedagem, suporte e provedores para o modelo operacional específico. Mantenha matrizes de responsabilidade, acordos, caminhos de escalonamento e evidência de autoridade.

Chapter 04 — Governança e accountability

Atribua funções executivas, security, privacy, jurídico, operações, arquitetura, procurement, RH e service owners. Mantenha aprovações, exceções, decisões de risco, evidência de management review e ownership de ações corretivas.

Chapter 05 — Inventário de sistemas e dados

Inventarie aplicações, infraestrutura, endpoints, interfaces, serviços cloud, administradores, data stores, backups e terceiros relacionados a CJI. Mantenha owners, data flows, limites de sistema, dependências e histórico de mudanças.

Chapter 06 — Mapeamento da política de segurança

Mapeie requisitos CJIS aplicáveis para controles, procedimentos, configurações técnicas, objetos de evidência e métodos de teste. Preserve rastreabilidade até a versão exata da política controlada.

Chapter 07 — Screening e suitability de pessoal

Defina screening, autorização, onboarding, alterações de status, suspensão e offboarding para pessoal com acesso ou funções de suporte relevantes. Mantenha evidência de conclusão, decisões, exceções e revisão periódica.

Chapter 08 — Conscientização e treinamento por função

Forneça treinamento CJIS baseado em funções e alinhado às responsabilidades de acesso, administração, operação e incidentes. Mantenha currículo, conclusão, competency checks, remediação e gatilhos de atualização.

Chapter 09 — Proteção física

Defina controles de acesso físico, visitantes, instalações, workspace, dispositivos, media e ambiente para ambientes CJI aplicáveis. Mantenha registros de acesso, revisões de instalações, exceções e ações corretivas.

Chapter 10 — Ciclo de vida de identidades e contas

Controle solicitação, aprovação, provisioning, modificação, revisão periódica, suspensão e encerramento de contas. Mantenha evidência de identidade, ownership de conta, marcação de privilégios, resultados de review e tempos de revogação.

Chapter 11 — Autenticação avançada e MFA

Aplique controles de autenticação apropriados ao cenário de usuário, dispositivo, rede, acesso remoto e privilégios conforme a linha de base CJIS vigente e requisitos CSA aplicáveis. Registre desenho técnico, exceções, testes e controles compensatórios quando permitidos.

Chapter 12 — Acesso privilegiado

Restrinja acessos privilegiados a pessoal autorizado e caminhos administrativos aprovados. Mantenha inventários de funções privilegiadas, justificativas, session controls, monitoring, evidência de review e procedimentos break-glass.

Chapter 13 — Menor privilégio e controle de acesso

Implemente autorização adequada à função, segregação de funções, need-to-know, recertificação periódica e governança de mudanças de acesso. Mantenha matrizes, aprovações, exceções e evidência de teste.

Chapter 14 — Criptografia em trânsito

Proteja CJI em trânsito por conexões internas, externas, remotas, wireless, cloud e de terceiros usando mecanismos criptográficos aprovados. Mantenha baselines de protocolo, evidência de certificados/keys, configuration checks e exceções.

Chapter 15 — Criptografia em repouso

Proteja CJI armazenada quando exigido pelo contexto aplicável CJIS/CSA. Mantenha inventários de storage, decisões de criptografia, settings técnicos, dependências de chaves, exceções e evidência de validação.

Chapter 16 — Governança criptográfica e de chaves

Defina ownership, geração, armazenamento, rotação, revogação, recuperação, backup e aposentadoria de chaves/certificados que protegem CJI. Mantenha inventários, custodians, registros de mudança e resultados de testes.

Chapter 17 — Logging e registros de auditoria

Capture eventos relevantes para segurança em sistemas CJI, atividade administrativa, autenticação, acesso, mudanças de configuração e investigação de incidentes conforme aplicável. Mantenha escopo, racional de retenção, access controls, evidência de review e exceções.

Chapter 18 — Monitoring e sincronização de tempo

Mantenha monitoring, alerting, time synchronization, event correlation e escalonamento suficientes para operações de segurança e integridade de evidência. Preserve cobertura, fontes de tempo, tratamento de alertas e evidência de revisão.

Chapter 19 — Proteção de media

Controle criação, marcação, armazenamento, transporte, reutilização, sanitização e descarte de media com CJI. Mantenha chain of custody, evidência de sanitização, destruição, exceções e verificações periódicas.

Chapter 20 — Acesso móvel, remoto e wireless

Governe dispositivos móveis, acesso remoto, teletrabalho, conectividade wireless e sistemas portáteis conforme aplicabilidade e risco documentados. Mantenha configurações aprovadas, autorização de usuários, device controls, métodos de conexão, monitoring e exceções.

Chapter 21 — Arquitetura de rede e segurança

Documente segmentação, trust boundaries, security zones, conexões externas, management networks, caminhos administrativos e tecnologias protetoras. Mantenha diagramas, configuration baselines, aprovações e revisões.

Chapter 22 — Vulnerabilidades, patching e configuração

Defina identificação, priorização e remediação de vulnerabilidades, patching, secure configuration, change control e exceções para sistemas CJI e dependências. Mantenha scans/tests, tracking de remediação, baselines aprovados e decisões de risco.

Chapter 23 — Resposta e reporte de incidentes

Integre eventos CJI em intake, triage, containment, preservação de evidência, escalonamento, reporting, recuperação e lessons learned. Mantenha incident records, decisões de notificação, timelines, comunicações e ações corretivas.

Chapter 24 — Governança de cloud e service providers

Avalie cloud, managed, hosted, SaaS, suporte e infraestrutura para aplicabilidade CJI, responsabilidades, acesso, localização de dados, segurança, monitoring, subcontracting,

incidentes, retenção e saída. Mantenha due diligence, contratos, arquitetura, aprovações e oversight.

Chapter 25 — Outsourcing, security addenda e acordos

Mantenha acordos exigidos, security addenda, controles contratuais, declarações de responsabilidade e evidência de conformidade para terceiros. Distinga política FBI, implementação CSA, deveres contratuais e controles internos.

Chapter 26 — Backup, resiliência e continuidade

Proteja backups e capacidades de recuperação de sistemas CJI em conformidade com requisitos de segurança, disponibilidade, integridade e acesso. Mantenha inventários, restoration tests, recovery objectives, decisões de processamento alternativo e ações corretivas.

Chapter 27 — Retenção e descarte de dados

Defina retenção, arquivamento, exclusão, sanitização, legal hold e disposal usando requisitos CJIS, records, legais, contratuais e de agência aplicáveis. Não apresente CJIS como calendário universal de retenção.

Chapter 28 — Auditorias e assessments

Planeje e execute reviews internos, technical testing, validação de evidência, assessments externos/CSA e tracking de remediação. Mantenha escopo, amostras, findings, severidade, ownership, datas, retests e decisões de encerramento.

Chapter 29 — Ações corretivas e exceções

Governe findings, corrective actions, desvios temporários, compensating measures, risk acceptance, expiração e reapproval. Mantenha root cause, owner, target date, evidência, approvals e validação de encerramento.

Chapter 30 — Métricas e management review

Acompanhe exceções de access review, patches vencidos, findings de privilégios, training completion, incidentes, findings abertos, problemas de provedores e change-watch. Management review deve documentar decisões, recursos, escalonamento e prioridades.

Chapter 31 — Localização, proveniência e evidência de release

Congele candidatos EN/es-419/pt-BR antes da revisão final exata. Vincule identidades DOCX/PDF a SHA-256 e preserve estrutura, paridade, acessibilidade, rendered-page review, versão de fontes, workflow security e staging.

Chapter 32 — Roadmap e reverificação no release

Implemente por fases: aplicabilidade/inventário; governança; pessoas/acesso; arquitetura/criptografia; logging/monitoring; endpoint/media/remoto; provedores; incidentes/resiliência; assurance; melhoria contínua. Antes de publicar, reverifique a versão vigente da FBI CJIS Security Policy e requisitos CSA aplicáveis; a publicação permanece sequencial após o Manual 39.